

Industrial Security (Bachelor)

Solution Sheet – Section 10 Incident Response and Recovery

Exercise 10.1 – Playbook (sample structure)

Trigger: OT IDS alert – unsolicited Modbus write from corporate subnet.

Roles: OT IR lead (incident commander), control engineer (process impact), IT SOC (forensics), plant manager (decisions), communications (external).

First 60 min:

1. Confirm alert is not a false positive.
2. Notify operator in the control room; verify HMI vs. raw PLC values.
3. Block the source IP at the iDMZ firewall (do *not* disconnect PLC).
4. Snapshot relevant network captures from the IDS.
5. Page plant manager and on-call OT IR.

Containment options: (a) source-host isolation in IT, (b) PLC mode switch to local-only, (c) emergency manual operation. Document process impact of each.

Recovery: re-image source host, rotate affected credentials, increase monitoring, run post-incident review within 5 working days.

Exercise 10.2 – Tabletop (mark scheme)

Award marks for: safety-first thinking (no rash disconnects); calling for control engineer expertise early; preserving forensic evidence (PCAP, logs); clear comms; documenting decisions; identifying *when* to involve external CERT/regulators.

Exercise 10.3 – Forensic Report (mark scheme)

Award marks for: correct attacker IP, accurate timeline (Wireshark filter `modbus.func_code == 6`), process impact described in operator terms, clean executive summary at the top, recommendations distinct from facts.

Exercise 10.4 – Business Continuity (sample)

System	RTO	RPO	Notes
SCADA	4 h	1 h	Spare server image + last config
Historian	24 h	24 h	Off-site immutable backup
PLC	1 h	0 h	Cold spare on the shelf
HMI	2 h	N/A	Spare workstation image

Manual ops procedure: pre-printed run-cards per loop, local panel readings, two-operator rule for valve operations, hourly logsheets to be entered into Historian on recovery.